



Your House has an FFmpeg Problem

An abstract background graphic consisting of several light gray rectangular blocks of varying heights and widths, arranged in a staggered, stepped pattern on the right side of the slide.

\$ whoami

Jia Hao Poh

Senior Security Consultant at
elttam



Agenda

What we will be looking at today



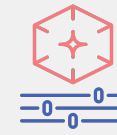
Home Assistant (HA) Primer

- What is it?
- Threat modeling
- Previously known vulnerabilities



Vulnerability Hunting and FFmpeg Abuse

- Attack chain... primitives?
- Technical details of the vulnerability
- Building a working exploit



The Patch

- How does the official patch look?

HA Primer

What is it?

What is HA?

Manage and automate all smart home devices, no cloud services required

Local controls and privacy first 🏆



<https://github.com/home-assistant>

What is HA?



Home Assistant · [Join](#)

██████████ · 6 July 2025 · 🌐

What are cheap smart toasters that work with Home Assistant?

🔮 Titles are generated by AI from Meta

Today our toaster died. Any recommendations for cheap "smart" toasters that might work with HA? Even though I'm not sure if it's useful to have a smart toaster.

😄👍 16

64 comments

👍 Like

💬 Comment

➦ Share

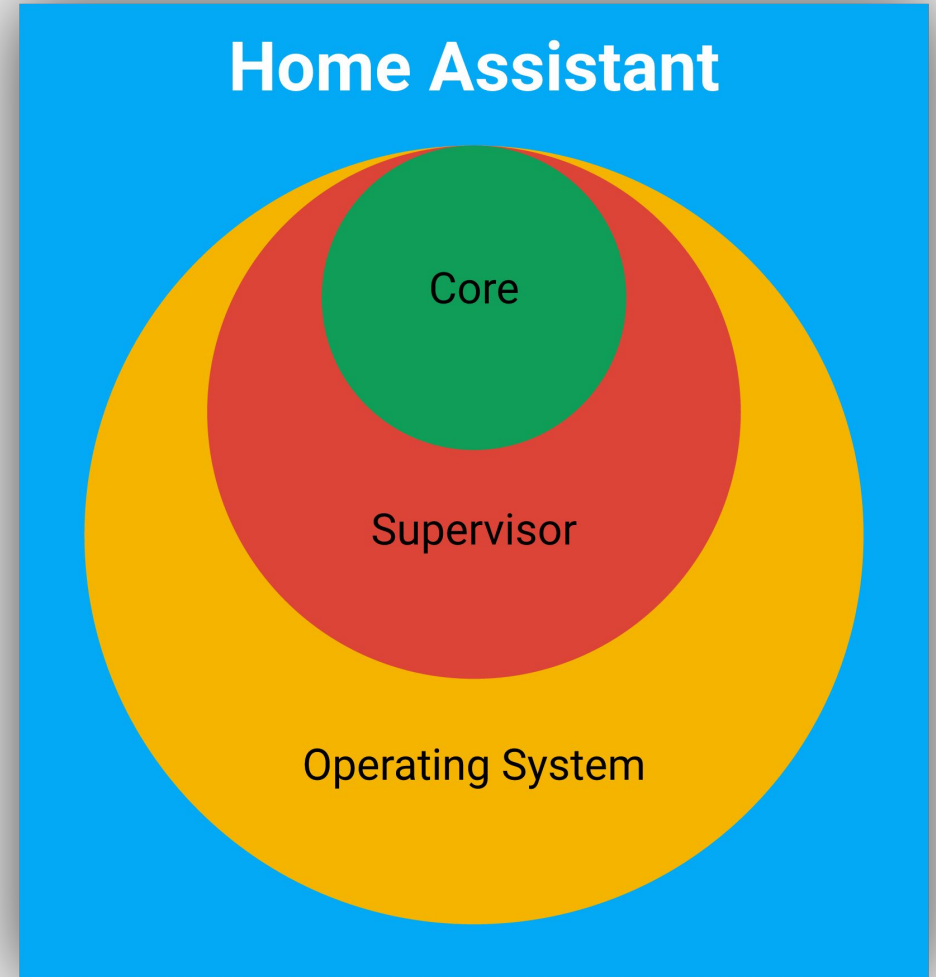
<https://github.com/home-assistant>

Components

Core: Main component of HA. Contains all the HA features and capabilities. Web server at tcp/8123

Supervisor: Manages Core, e.g., keeping the service up, updating Core

OS: The underlying host system. Can be the HAOS or any other platforms.



HA Primer

Attack Surface Analysis

User Roles

 **Home Assistant** 2026.8.2 

ON THIS PAGE > About user accounts

About user accounts

When you start Home Assistant for the first time, the *owner* user account is created. The owner has the highest level of access and can manage every part of the system, including creating and managing other user accounts.

User accounts come in two levels of access:

- *Administrators* can configure integrations, devices, and system settings, and manage other users. The owner is always an administrator.
- *Non-administrator users* have restricted access. They can use Home Assistant and see their own dashboards, but cannot reach the configuration and system settings.

You set whether a user is an administrator with the **Administrator** toggle when you create or edit their account.

User Roles

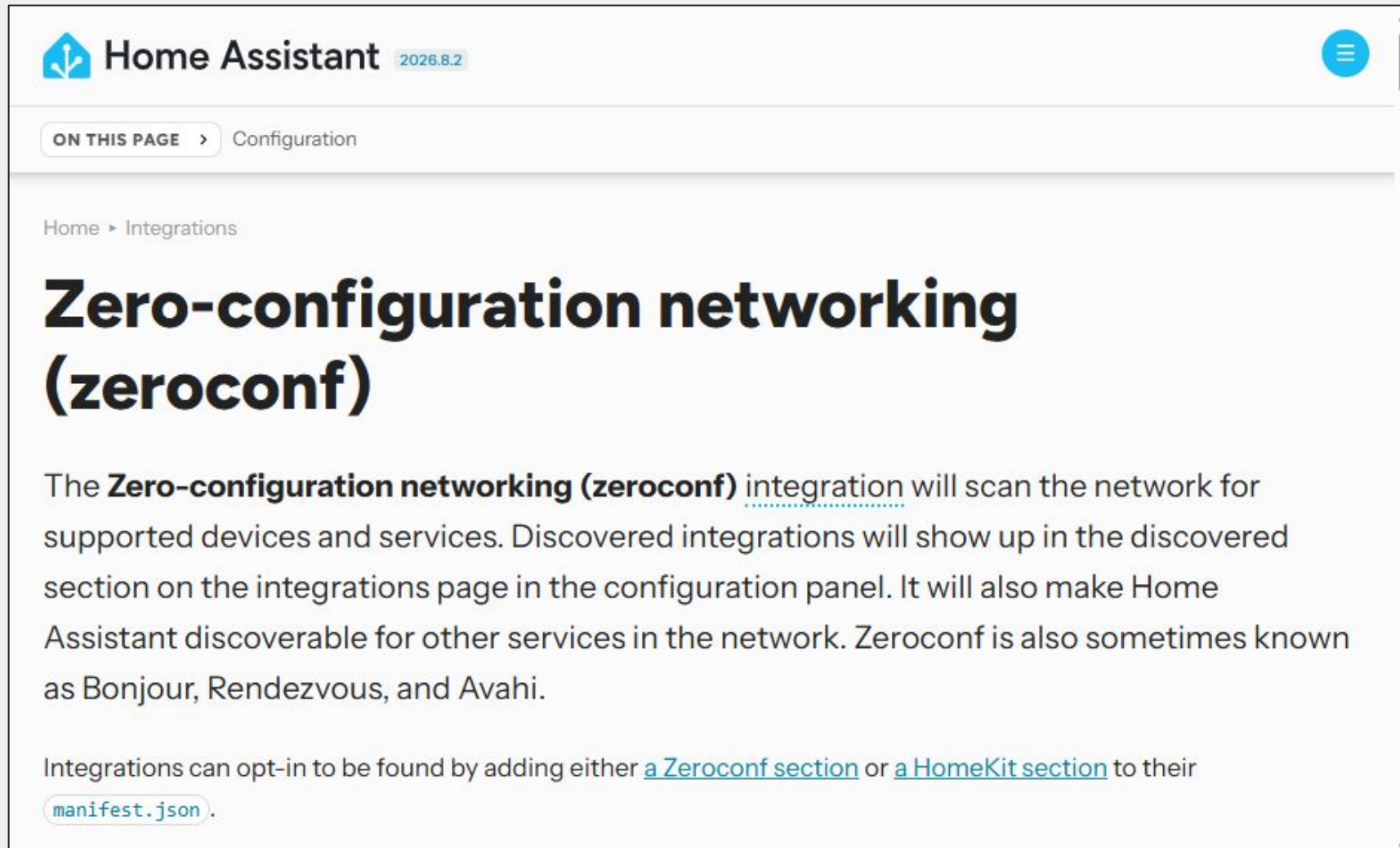


Home Assistant 2026.8.2

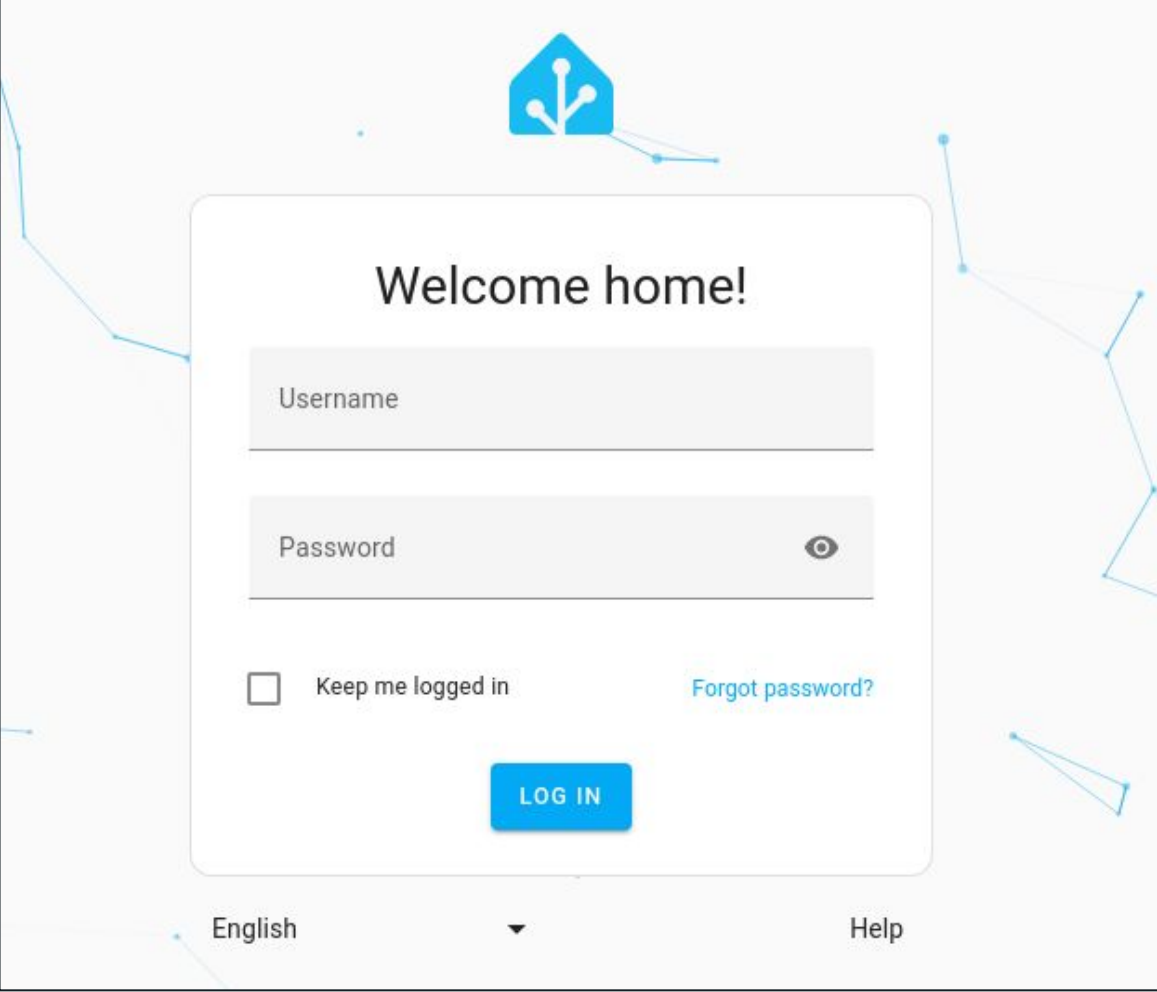


- Reports from automated tools or scanners.
- Theoretical attacks without proof of exploitability.
- Attacks that are the result of a third-party application or library (these should instead be reported to the library maintainers).
- Social engineering.
- Attacks that require the user to have access to the Home Assistant host system.
- Attacks involving physical access to a user's device, or involving a device or network that's already seriously compromised (like, man-in-the-middle).
- Attacks that require the user to install a malicious other software, like a third-party integration, app (formerly known as add-ons), or plugin.
- Attacks that the user can only perform against their own setup.
- Privilege escalation attacks for logged in users. Home Assistant assumes every user is trusted and does not enforce user privileges. It assumes every logged in user has the same access as an owner account ([more information](#)).

Reachability



Reachability





Welcome home!

Username

Password 

☐ Keep me logged in

[Forgot password?](#)

LOG IN

English ▼

[Help](#)

HA Primer

Previous vulnerabilities

Known Vulnerabilities

[CVE-2023-27842](#) - elttam



<https://www.elttam.com/blog/pwnassistant>

Known Vulnerabilities

CVE-2023-27842 - elttam

CVE-2023-41893 to CVE-2023-41897
- Cure53

 **Home Assistant** 2023.8.2 [Getting started](#) [Documentation](#) ▾

2023-10-19: Account takeover via auth_callback login

Severity: *Low*

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41893](#)

Discovered by: [Cure53](#) (Funded by [Nabu Casa](#))

Fixed in: Home Assistant Core 2023.9

2023-10-19: Full takeover via javascript URI in auth_callback login

Severity: *Critical*

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41895](#)

Discovered by: [Cure53](#) (Funded by [Nabu Casa](#))

Fixed in: Home Assistant Core 2023.9

2023-10-19: Local-only webhooks externally accessible via SniTun

Severity: *Low*

Detailed information: [Security advisory](#)

2023-10-19: Fake WS server installation permits full takeover

Severity: *Critical*

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41896](#)

Discovered by: [Cure53](#) (Funded by [Nabu Casa](#))

Fixed in: Home Assistant Core 2023.9 & [home-assistant-js-websocket](#) 8.2.0 (npm)

2023-10-19: Lack of XFO header allows clickjacking

Severity: *Critical*

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41897](#)

Discovered by: [Cure53](#) (Funded by [Nabu Casa](#))

Fixed in: Home Assistant Core 2023.9

Known Vulnerabilities

CVE-2023-27842 - elttam

CVE-2023-41893 to CVE-2023-41897
- Cure53

**CVE-2023-41898, CVE-2023-41899,
CVE-2023-44385** - GitHub Security
Lab

Home Assistant 2026.8.2

2023-10-19: Actions expression injection in `helpers/version/action.yml`

Severity: Low (*This is an internal project*)

Detailed information: [Security advisory](#)

Discovered by: [Jorge Rosillo](#), [Peter Stöckli](#) ([GitHub Security Lab](#))

Fixed in: Home Assistant GitHub Actions released on September 5, 2023

2023-10-19: Arbitrary URL load in Android WebView in `MyActivity.kt`

Severity: High (CVSS: 8.6)

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41898](#)

Discovered by: [Tony Torralba](#) ([GitHub Security Lab](#))

Fixed in: Home Assistant for Android 2023.9.2

2023-10-19: Partial Server-Side Request Forgery in Core

Severity: Low

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-41899](#)

Discovered by: [Alvaro Muñoz](#) ([GitHub Security Lab](#))

Fixed in: Home Assistant Core 2023.9

2023-10-19: Client-Side Request Forgery in iOS/macOS native Apps

Severity: High (CVSS: 8.6)

Detailed information: [Security advisory](#)

Assigned CVE: [CVE-2023-44385](#)

Discovered by: [Alvaro Muñoz](#) ([GitHub Security Lab](#))

Fixed in: Home Assistant for iOS 2023.7

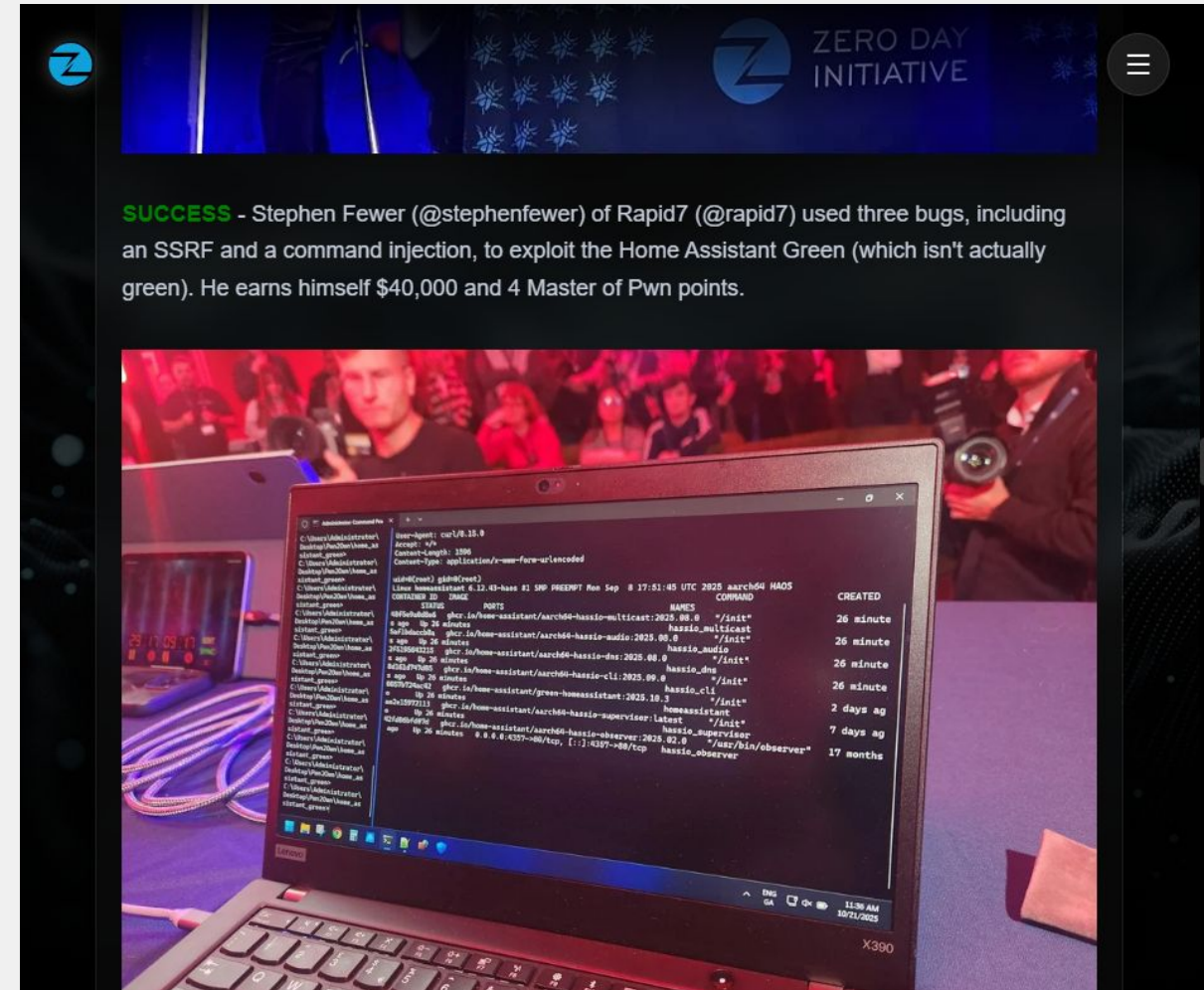
Known Vulnerabilities

CVE-2023-27842 - elttam

CVE-2023-41893 to CVE-2023-41897
- Cure53

CVE-2023-41898, CVE-2023-41899,
CVE-2023-44385 - GitHub Security
Lab

Pwn2Own Entries - 4 successes





Upcoming

2026 ▼

Q home assistant

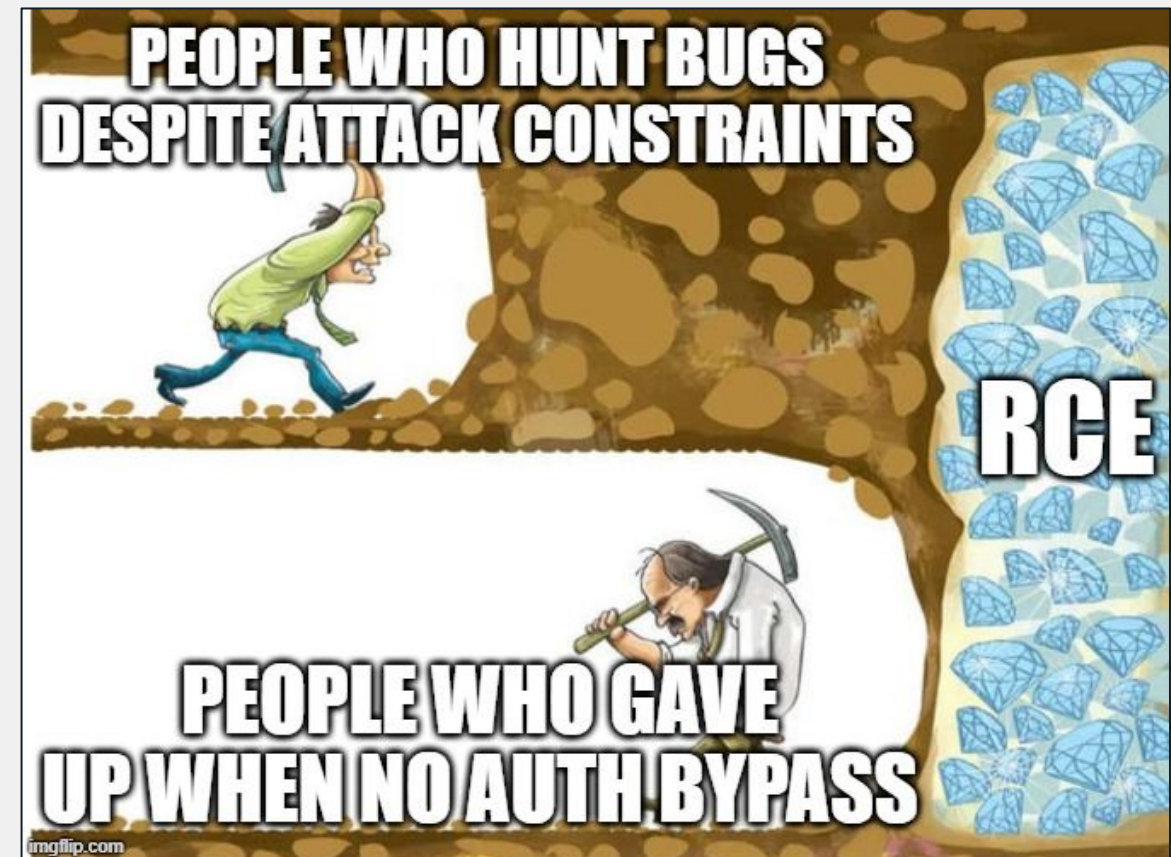


Vulnerability Hunting and FFmpeg Abuse

Attack chain primitives

High-impact Primitives

Do you keep researching on a target even if you could not locate any pre-auth bugs?



Vulnerability Hunting and FFmpeg Abuse

Technical details of the vulnerability

Wyoming Protocol Integration

Allow users to use speech-to-text to manage devices in their smart homes


Home Assistant
2026.8.2

[Getting started](#)
[Documentation](#)
[Our hardware](#)
[Integrations](#)
[Blog](#)
[Need help?](#)

[ON THIS PAGE](#)
[Installing a local voice pipeline](#)

[Home](#)
[Integrations](#)

Wyoming Protocol

The **Wyoming** integration connects external voice services to Home Assistant using a [small protocol](#). This enables [Assist](#) to use a variety of local [speech-to-text](#), [text-to-speech](#), and [wake-word-detection](#) systems, such as:

- Speech-to-Phrase [SHOW APP ON](#) [MY](#)
- Whisper [SHOW APP ON](#) [MY](#)
- Piper [SHOW APP ON](#) [MY](#)
- openWakeWord [SHOW APP ON](#) [MY](#)

INSTALLING A LOCAL VOICE PIPELINE

The Wyoming, Piper, and Whisper apps for Home Assistant (formerly known as add-ons) are used to create a fully local voice pipeline. To learn how to do this, follow the procedure on [installing a local voice pipeline](#).



[ADD INTEGRATION TO](#) [MY](#)

The Wyoming Protocol service was introduced in Home Assistant 2023.5, and it's used by 8.9% of the active installations.

Its IoT class is [Local Push](#).

[View source on GitHub](#)
[View known issues](#)
[View feature requests](#)

INTEGRATION OWNERS

We are incredibly grateful to the following contributors who currently maintain this integration:


[@synesthesiam](#)

core/blob/dev/homeassistant/components/wyoming/assist_satellite.py

```
try:
    # Use ffmpeg to convert to raw PCM audio with the appropriate format
    proc = await asyncio.create_subprocess_exec(
        self._ffmpeg_manager.binary,
        "-i",
        announcement.media_id,
        "-f",
        "s16le",
        "-ac",
        str(SAMPLE_CHANNELS),
        "-ar",
        str(_TTS_SAMPLE_RATE),
        "-nostats",
        "pipe:",
        stdout=asyncio.subprocess.PIPE,
        stderr=asyncio.subprocess.PIPE,
        close_fds=False, # use posix_spawn in CPython < 3.13
    )
```

Attacker-controlled value

-i <USER_INPUT> -f s16le -ac 1 -ar 22050

FFmpeg

About

News

Download

Documentation

Community

Code of Conduct

Mailing Lists

Note: the old undocumented way of specifying per-stream AVOptions by prepending v/a/s to the options name is now obsolete and will be removed soon.

5.4 Main options

-f *fmt* (*input/output*)

Force input or output file format. The format is normally auto detected for input files and guessed from the file extension for output files, so this option is not needed in most cases.

-i *url* (*input*)

input file url

-y (*global*)

Overwrite output files without asking.

Would **-i file:///proc/self/environ** work?

Raw audio in FFmpeg can take several different "forms", i.e. sample formats. For instance:

- `s` means "signed" (for the integer representations), `u` would mean "unsigned"
- 16 means 16 Bits per sample
- `le` means "little endian" coding for the samples

You can see a list of supported sample formats by inspecting the `ffmpeg -formats` output:

```
$ ffmpeg -formats | grep PCM
DE alaw          PCM A-law
DE f32be         PCM 32-bit floating-point big-endian
DE f32le         PCM 32-bit floating-point little-endian
DE f64be         PCM 64-bit floating-point big-endian
DE f64le         PCM 64-bit floating-point little-endian
DE mulaw         PCM mu-law
DE s16be         PCM signed 16-bit big-endian
DE s16le         PCM signed 16-bit little-endian
DE s24be         PCM signed 24-bit big-endian
DE s24le         PCM signed 24-bit little-endian
DE s32be         PCM signed 32-bit big-endian
DE s32le         PCM signed 32-bit little-endian
DE s8           PCM signed 8-bit
DE u16be         PCM unsigned 16-bit big-endian
DE u16le         PCM unsigned 16-bit little-endian
DE u24be         PCM unsigned 24-bit big-endian
DE u24le         PCM unsigned 24-bit little-endian
DE u32be         PCM unsigned 32-bit big-endian
DE u32le         PCM unsigned 32-bit little-endian
DE u8           PCM unsigned 8-bit
```

These represent all the built-in raw audio sample formats.

 FFmpeg

About

News

Download

Documentation

Community

Code of Conduct

Mailing Lists

new obsolete

extension for

`-i <USER_INPUT> -f s16le -ac 1 -ar 22050`

 FFmpeg

About

News

Download

Documentation

Community

Code of Conduct

Mailing Lists

IRC

Forums

Bug Reports

Wiki

Conferences

Developers

Source Code

5.7 Audio Options

-aframes *number* (*output*)
Set the **number** of audio frames to output. This is an obsolete alias for `-frames:a`, which you should use instead.

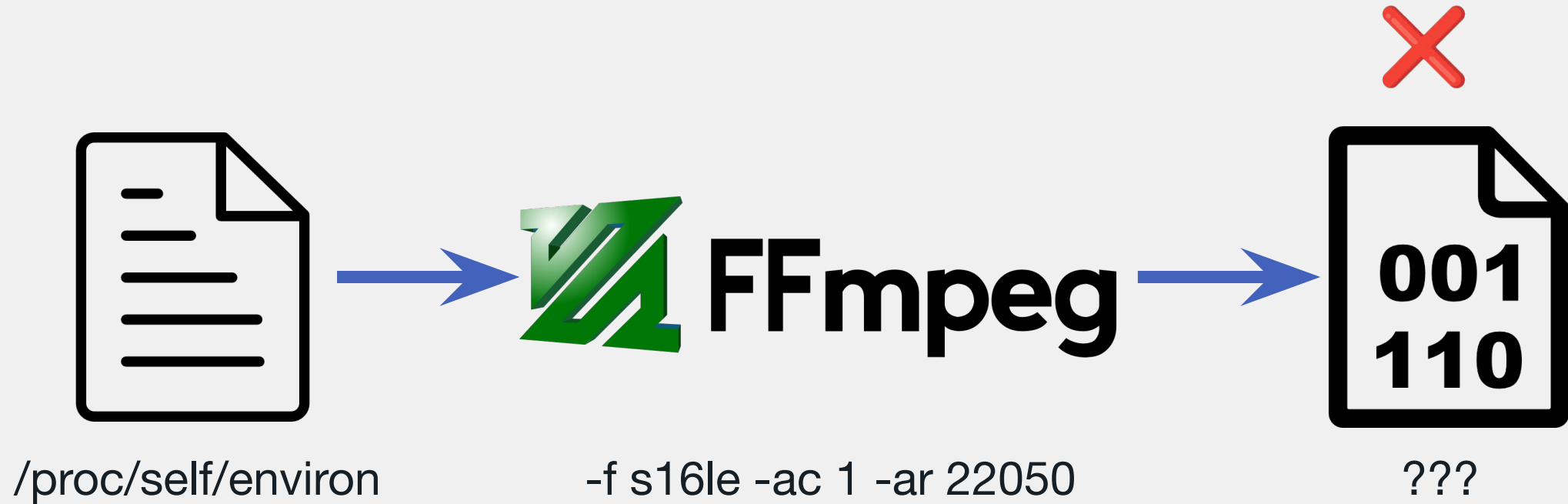
-ar[:*stream_specifier*] *freq* (*input/output,per-stream*)
Set the audio sampling frequency. For output streams it is set by default to the frequency of the corresponding input stream. For input streams this option only makes sense for audio grabbing devices and raw demuxers and is mapped to the corresponding demuxer options.

-aq *q* (*output*)
Set the audio quality (codec-specific, VBR). This is an alias for `-q:a`.

-ac[:*stream_specifier*] *channels* (*input/output,per-stream*)
Set the number of audio channels. For output streams it is set by default to the number of input audio channels. For input streams this option only makes sense for audio grabbing devices and raw demuxers and is mapped to the corresponding demuxer options.

-an (*input/output*)
As an input option, blocks all audio streams of a file from being filtered or being automatically selected or mapped for any output. See `-discard` option to disable streams individually.

As an output option, disables audio recording i.e. automatic selection or mapping of any audio stream. For full manual control



Vulnerability Hunting and FFmpeg Abuse

Building a working exploit

Attack Constraints

- Attacker's "Wyoming satellite" must already be added to the HA network
- Attacker needs a valid HA API token to interact with the vulnerable "announce" endpoint

Exploitation

Building the Payload

FFmpeg is encoding our input because it is not compliant with the output format

Exploitation

Building the Payload

FFmpeg is encoding our input because it is not compliant with the output format

What if...

Trick FFmpeg into thinking that the input file matches the output format?



Exploitation

Building the Payload... Header(?)

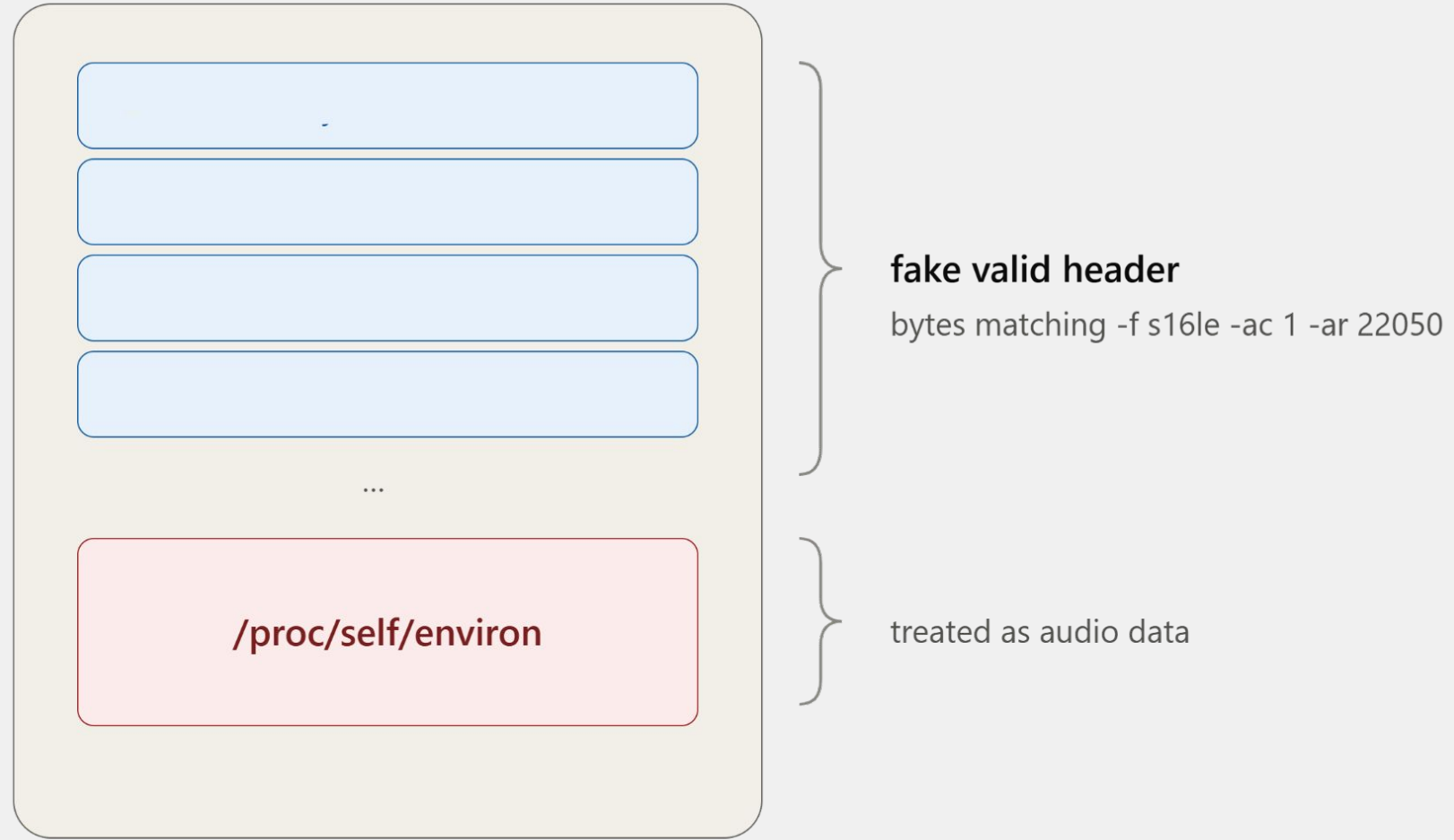
FFmpeg accepts certain custom URL schemes such as:

file
concat
subfile

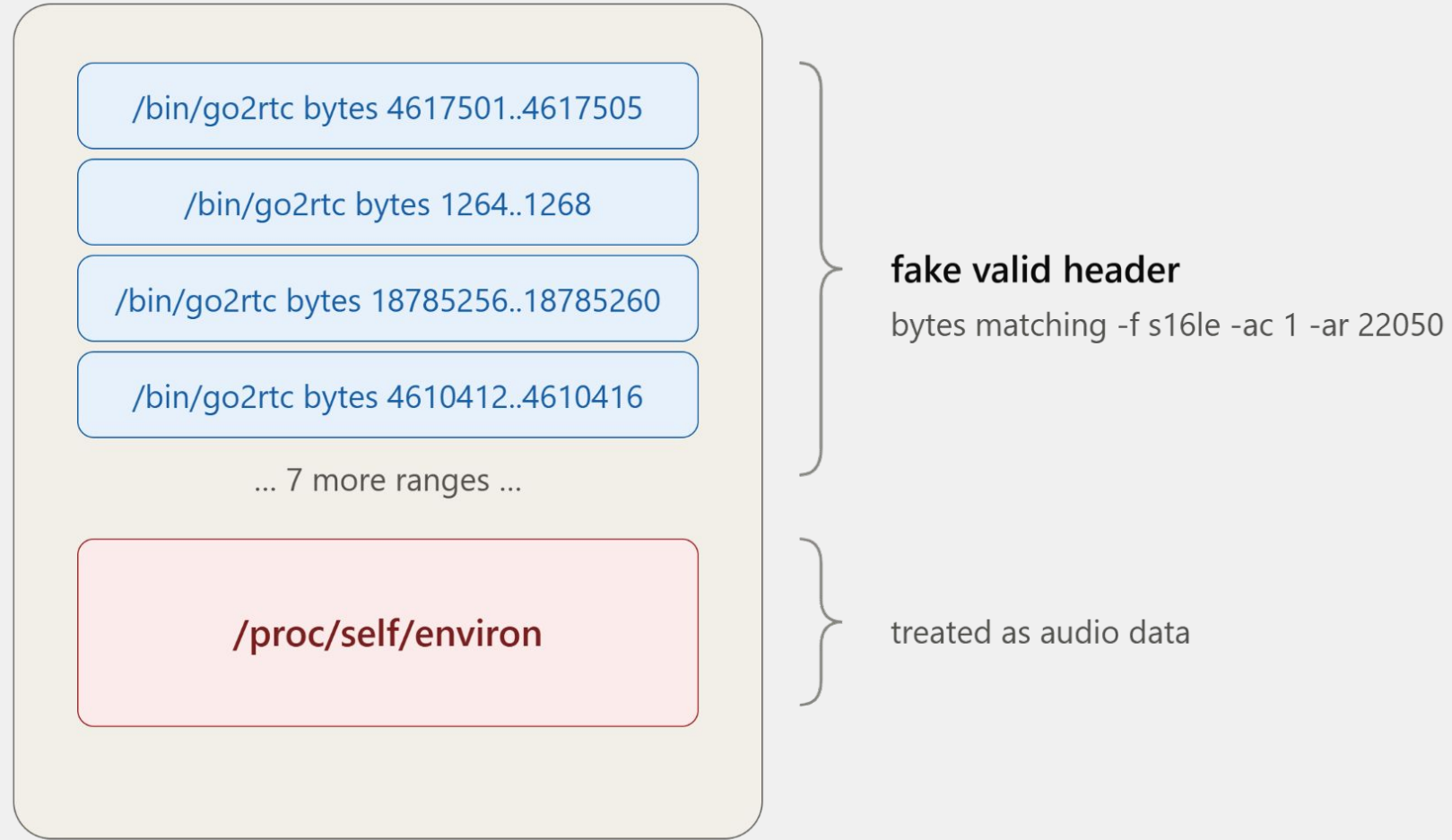
Schemes can be **chained** together with **concat**, and we can use different segments of a binary file with **subfile**.

What if we create a compliant header before concatenating **/proc/self/envIRON?**

Exploitation



Exploitation

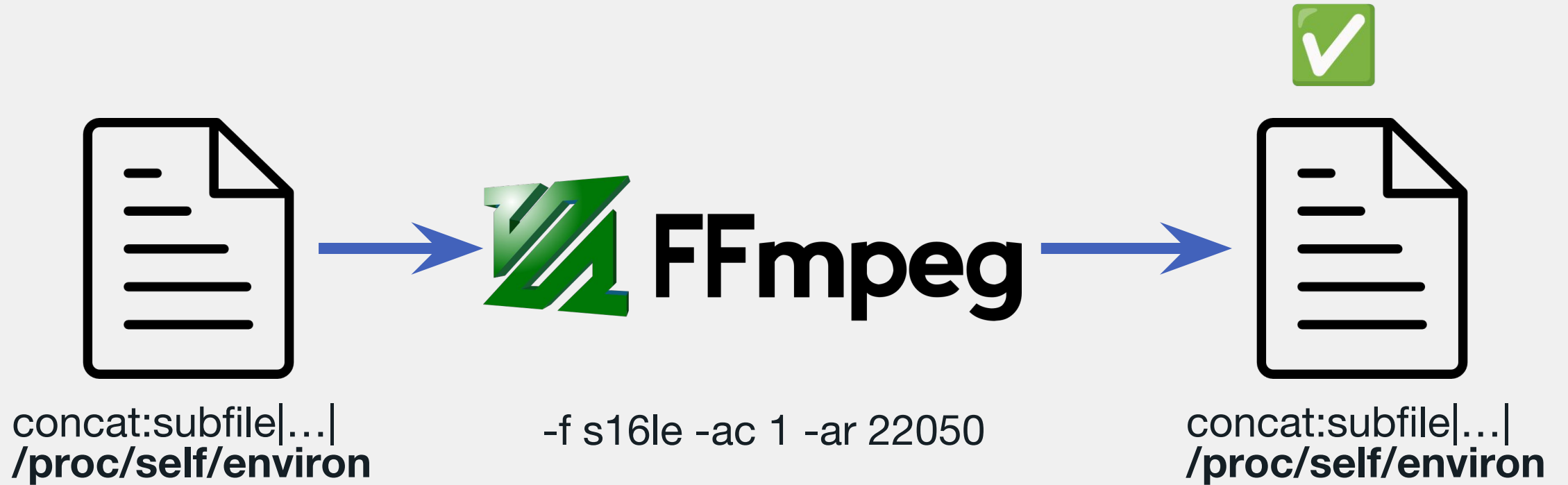


ffmpeg accepts the stitched header, then treats environ as audio data.

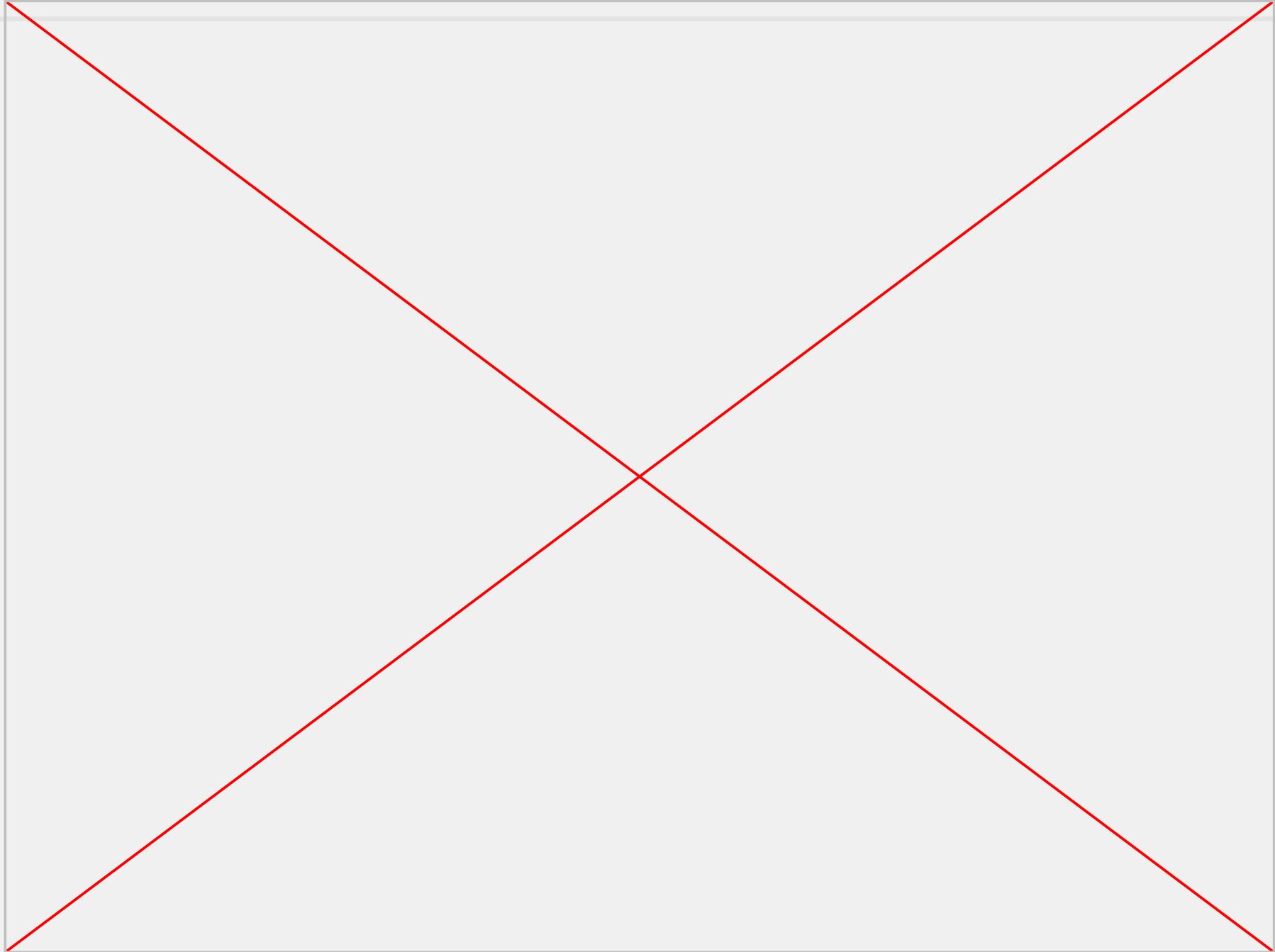
Exploitation

Building the Payload

```
concat:subfile,,start,4617501,end,4617505,,:/bin/go2rtc|subfile,,start,1264,end,1268,  
:/bin/go2rtc|...|/proc/self/envIRON
```



Demo



The Patch

How's the patch?



core/blob/dev/homeassistant/components/wyoming/assist_satellite.py

```
try:
    # Use ffmpeg to convert to raw PCM audio with the appropriate format
    proc = await asyncio.create_subprocess_exec(
        self._ffmpeg_manager.binary,
        "-protocol_whitelist",
        "http,https,file,tcp,tls",
        "-i",
        announcement.media_id,
        "-f",
        "s16le",
        "-ac",
        str(SAMPLE_CHANNELS),
        "-ar",
        str(_TTS_SAMPLE_RATE),
        "-nostats",
        "pipe:",
        stdout=asyncio.subprocess.PIPE,
        stderr=asyncio.subprocess.PIPE,
        close_fds=False, # use posix_spawn in CPython < 3.13
    )
```



Restricts the allowed protocols

core/blob/dev/homeassistant/components/wyoming/assist_satellite.py

```
try:
```

```
# Use ffmpeg to convert to raw PCM audio with the appropriate format
proc = await asyncio.create_subprocess_exec(
    self._ffmpeg_manager.binary,
    "-protocol_whitelist",
    "http,https,file,tcp,tls",
    "-i",
    announcement.media_id,
    "-f",
    "s16le",
```

Restricts the allowed protocols

FFmpeg

About

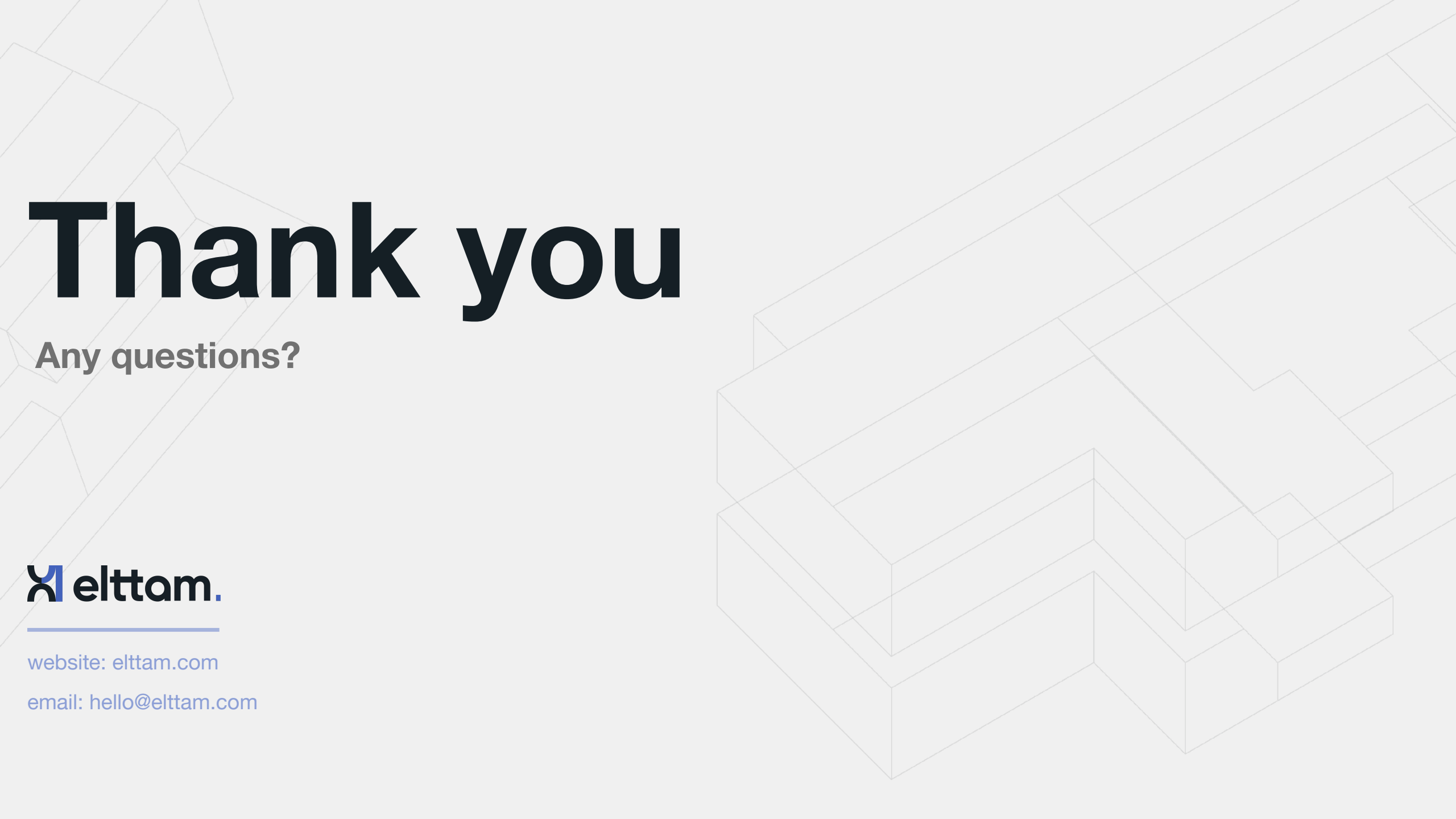
News

input/output are referred to by their indices. E.g. `2:3` refers to the fourth stream in the third input or output. Also see the [Stream specifiers](#) chapter.

As a general rule, options are applied to the next specified file. Therefore, order is important, and you can have the same option on the command line multiple times. Each occurrence is then applied to the next input or output file. Exceptions from this rule are the global options (e.g. verbosity level), which should be specified first.

Downloaded from [ffmpeg.org](#), if you use posix_spawn in Python < 3.7.0

)



Thank you

Any questions?



website: elttam.com

email: hello@elttam.com